

Security+ 5.2 · Risk Management

Mestre CyberSec · Aula 5.2 — Risk Management (3:30) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Risk = AMEAÇA × VULNERABILIDADE × IMPACTO no ativo. Assessment (quantitativo em \$ ou qualitativo alto/médio/baixo); ad-hoc (sob demanda); recurring (periódico com register atualizado).

💡 Highlights que a prova CompTIA cobra

- Risk = ameaça × vulnerabilidade × impacto no ativo
- Risk register: o inventário vivo de risco com owner e plano

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'likelihood x impact'=risk

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Risco (N/A)

A probabilidade de que uma ameaça explore uma vulnerabilidade e cause impacto a um ativo. Calculado como Ameaça × Vulnerabilidade × Impacto, ou alternativamente Probabilidade × Impacto para a prova.

⚠ **Armadilha CompTIA:** Messer teaches BOTH formulas: $Threat \times Vulnerability \times Impact$ AND $Likelihood \times Impact = Risk$. Know both to handle any wording on the exam.

• Registro de Riscos (N/A)

Documento/inventário vivo que lista todos os riscos identificados, incluindo o dono do risco, probabilidade, impacto, plano de mitigação e status. É continuamente atualizado em avaliações periódicas.

⚠ **Armadilha CompTIA:** If the question describes a 'living document' or 'inventory of risks' with an owner and mitigation plan, the answer is Risk Register. It's the centerpiece output of recurring assessments.

• Avaliação Quantitativa de Risco (N/A)

Avaliação de risco que atribui valores monetários/em dólares (ex.: ALE, SLE, ARO) aos riscos, produzindo resultados numéricos objetivos e diretamente comparáveis.

⚠ **Armadilha CompTIA:** Trigger words: 'dollar amounts,' 'ALE,' 'SLE,' 'ARO,' 'cost-benefit.' If numbers and money are involved, it's quantitative — not qualitative.

• Avaliação Qualitativa de Risco (N/A)

Avaliação de risco que usa classificações subjetivas como alto/médio/baixo ou vermelho/amarelo/verde para ordenar riscos com base em probabilidade e impacto, sem valores em dinheiro.

⚠ **Armadilha CompTIA:** Trigger words: 'high/medium/low,' 'subjective,' 'scenario-based,' 'expert opinion.' Cheaper and faster than quantitative, but no dollar figure attached.

• Ameaça (N/A)

Qualquer evento ou ator potencial (natural, humano ou ambiental) que pode causar dano explorando uma vulnerabilidade em um sistema ou ativo.

⚠ **Armadilha CompTIA:** Don't confuse Threat with Vulnerability. The Threat is the actor/event (e.g., hacker, flood); the Vulnerability is the weakness (e.g., unpatched software).

• Vulnerabilidade (N/A)

Uma fraqueza, falha ou lacuna conhecida em um sistema, processo ou controle que pode ser explorada por uma ameaça para causar dano a um ativo.

⚠ **Armadilha CompTIA:** If you see CVE numbers, missing patches, or misconfigurations — that's a Vulnerability, not a Threat. Risk only exists when a Threat pairs with a Vulnerability.

• Avaliação Periódica de Risco (N/A)

Revisão agendada e periódica dos riscos organizacionais (ex.: anual ou trimestral) que mantém o registro de riscos atualizado e reflete mudanças no cenário de ameaças.

⚠ **Armadilha CompTIA:** Recurring assessments = updated risk register on a schedule. Contrast with ad-hoc (on-demand after an event). The exam often asks which type maintains an 'up-to-date' register.

• Avaliação Ad-hoc de Risco (N/A)

Avaliação de risco sob demanda e situacional, disparada por um evento específico, como uma nova divulgação de vulnerabilidade, incidente ou grande mudança — sem cronograma fixo.

⚠ **Armadilha CompTIA:** Trigger phrases: 'after a zero-day disclosure,' 'following an incident,' 'when deploying a new system.' No schedule = ad-hoc; periodic schedule = recurring.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de riscos está conduzindo uma avaliação quantitativa de riscos do sistema de gestão do armazém da empresa, que possui valor de ativo de US\$ 800.000. Registros de incidentes mostram que enchentes interromperam a instalação em média uma vez a cada cinco anos, e cada enchente causaria perda total do sistema (100% de fator de exposição). Com base nessas informações, qual é a perda anualizada esperada (ALE)?

- A) US\$ 800.000
- B) US\$ 1.600.000
- C) US\$ 160.000
- D) US\$ 400.000

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa de saúde acabou de anunciar a aquisição de um provedor menor de telemedicina. O CISO deseja uma avaliação imediata e pontual da superfície de ataque combinada, dos fluxos de dados e da exposição regulatória antes que qualquer sistema seja integrado. Que tipo de avaliação de riscos é MAIS apropriado para essa necessidade desencadeada por um evento?

- A) Uma avaliação de riscos ad hoc
- B) Uma avaliação de riscos recorrente
- C) Um programa de monitoramento contínuo
- D) Uma auditoria de conformidade de linha de base

QUESTÃO 3 · CENÁRIO DE EXAME

A política de segurança de uma organização exige que a equipe de gestão de riscos reavalie todas as entradas do registro de riscos na primeira segunda-feira de cada trimestre fiscal, ajustando as pontuações de probabilidade e impacto e registrando o progresso das mitigações. Que tipo de avaliação de riscos essa política descreve?

- A) Uma avaliação de riscos ad hoc
- B) Uma avaliação de riscos recorrente
- C) Uma avaliação de riscos quantitativa
- D) Uma varredura de vulnerabilidades automatizada

QUESTÃO 4 · CENÁRIO DE EXAME

Um CISO recém-contratado pede para ver o documento em que a organização registra formalmente cada risco identificado, seu nível de risco atribuído, o responsável (owner), os controles e mitigações planejados e o status atual, para que a liderança possa acompanhar os esforços de tratamento ao longo do tempo. Qual produto do processo de gestão de riscos a equipe deve fornecer?

- A) Análise de impacto no negócio (BIA)
- B) Declaração de aplicabilidade (SOA)
- C) Plano de resposta a incidentes
- D) Registro de riscos

QUESTÃO 5 · CENÁRIO DE EXAME

Ao documentar uma avaliação de riscos para um varejista online, um analista registra duas constatações: (1) grupos criminosos organizados que visam ativamente dados de cartão de pagamento de e-commerce e (2) um formulário web voltado ao cliente que não valida entradas e permite SQL injection. O item 2 é MELHOR classificado como qual elemento da equação de risco?

- A) Uma vulnerabilidade, porque é uma fraqueza explorável no ativo
- B) Uma ameaça, porque coloca diretamente em perigo os dados de cartão armazenados
- C) Um impacto, porque quantifica o dano monetário potencial
- D) Um risco, porque combina probabilidade e consequência

QUESTÃO 6 · CENÁRIO DE EXAME

Após concluir uma avaliação qualitativa, uma equipe posiciona quatro riscos em uma matriz de probabilidade/impacto e precisa decidir a ordem de remediação. Qual risco deve receber a MAIOR prioridade de remediação?

- A) Risco A — Probabilidade: baixa; Impacto: crítico
- B) Risco B — Probabilidade: moderada; Impacto: moderado
- C) Risco C — Probabilidade: alta; Impacto: crítico
- D) Risco D — Probabilidade: alta; Impacto: baixo

QUESTÃO 7 · CENÁRIO DE EXAME

Um CISO deve apresentar os resultados de riscos ao conselho na próxima semana. A organização não possui uma base confiável de avaliação patrimonial, e a liderança deseja classificações simples e imediatamente comparáveis, como alto, médio e baixo, em vez de valores em dólares. Qual abordagem de avaliação MELHOR atende a esses requisitos?

- A) Avaliação quantitativa de riscos baseada na perda anualizada esperada (ALE)
- B) Avaliação qualitativa de riscos usando uma matriz de probabilidade e impacto
- C) Avaliação quantitativa de riscos baseada na perda única esperada (SLE)
- D) Avaliação quantitativa de riscos usando custo de reposição para cada ativo

QUESTÃO 8 · CENÁRIO DE EXAME

O subscritor de seguro cibernético de um banco exige estimativas documentadas, em valores monetários, das perdas anuais esperadas para calcular os prêmios, e o CFO precisa desses mesmos valores para justificar o orçamento. Que tipo de avaliação fornece o resultado necessário?

- A) Avaliação qualitativa de riscos com mapa de calor
- B) Avaliação ad hoc de riscos com pontuação narrativa
- C) Revisão recorrente do registro com atualizações de status
- D) Avaliação quantitativa de riscos com perda anualizada esperada (ALE)

QUESTÃO 9 · CENÁRIO DE EXAME

Uma auditoria constata que o registro de riscos da empresa foi preenchido uma única vez, há dois anos. Várias entradas ainda constam como 'alto' embora controles compensatórios tenham sido implementados no ano passado, e os riscos introduzidos por três novos aplicativos de negócio estão completamente ausentes. Qual mudança no programa de gestão de riscos MELHOR resolve essas constatações?

- A)** Programar avaliações ad hoc somente quando um executivo as solicitar
- B)** Estabelecer uma cadência recorrente de avaliação de riscos que revalide e atualize todas as entradas do registro
- C)** Substituir o registro por planilhas individuais de projeto mantidas pelos desenvolvedores
- D)** Recalcular todas as entradas de risco usando apenas valores patrimoniais quantitativos

QUESTÃO 10 · CENÁRIO DE EXAME

Durante uma sessão de integração de segurança para novos analistas de riscos, um estagiário afirma que 'ransomware é nosso maior risco'. O analista sênior explica como a gestão formal de riscos distingue os termos relacionados. Qual afirmação descreve com mais precisão o que é risco nessa metodologia?

- A)** Ameaça e risco são termos idênticos que descrevem dano potencial
- B)** Risco é qualquer fraqueza explorável presente em um sistema ou processo
- C)** Risco é a probabilidade de uma ameaça explorar uma vulnerabilidade e causar um impacto a um ativo
- D)** Risco é definido unicamente pelo valor monetário atribuído a um ativo durante a avaliação patrimonial

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — US\$ 160.000

A Perda Anualizada Esperada é o custo anual esperado de um risco: $ALE = SLE \times ARO$. Primeiro calcule a Perda Única Esperada: $SLE = \text{Valor do Ativo} \times \text{Fator de Exposição} = US\$ 800.000 \times 100\% = US\$ 800.000$. Como a enchente ocorre uma vez a cada cinco anos, $ARO = 0,2$. Portanto, $ALE = US\$ 800.000 \times 0,2 = US\$ 160.000$. A opção de US\$ 800.000 é a SLE, não o valor anualizado; as demais resultam de erros no cálculo da taxa de ocorrência.

Questão 2: Alternativa A — Uma avaliação de riscos ad hoc

Avaliações de riscos ad hoc são realizadas sob demanda, em resposta a um evento específico que as desencadeia, como uma fusão, um incidente grave ou um novo projeto de alto impacto. A avaliação pontual e pré-integração descrita aqui é um exemplo típico de avaliação ad hoc. Uma avaliação recorrente segue um cronograma fixo; o monitoramento contínuo é uma capacidade permanente de vigilância, não uma avaliação pontual; e uma auditoria de conformidade verifica a adesão a padrões, não avalia o risco organizacional como um todo.

Questão 3: Alternativa B — Uma avaliação de riscos recorrente

Uma avaliação de riscos recorrente ocorre em intervalos regulares e predeterminados (mensal, trimestral, anual) e atualiza o registro de riscos a cada ciclo. O ciclo trimestral fixo descrito pela política caracteriza claramente uma avaliação recorrente. As avaliações ad hoc são acionadas por eventos e não têm periodicidade fixa; 'quantitativa' descreve o método de medição (valores em dólares), não a frequência; e uma varredura de vulnerabilidades é um teste técnico, não um tipo de avaliação de riscos.

Questão 4: Alternativa D — Registro de riscos

O registro de riscos é o documento vivo — frequentemente uma planilha ou registro em plataforma de GRC — em que cada risco identificado é registrado com seu responsável, nível/pontuação de risco, tratamento planejado (mitigar, aceitar, transferir, evitar) e status atual. A BIA avalia a criticidade dos processos de negócio para apoiar o planejamento de continuidade; a Declaração de Aplicabilidade mapeia a seleção de controles da ISO/IEC 27001; e o plano de resposta a incidentes define os procedimentos para lidar com eventos de segurança.

Questão 5: Alternativa A — Uma vulnerabilidade, porque é uma fraqueza explorável no ativo

Uma vulnerabilidade é uma fraqueza intrínseca em um sistema, processo ou controle que poderia ser explorada. A falta de validação de entrada que permite SQL injection é uma fraqueza do próprio ativo, sendo portanto uma vulnerabilidade. O item 1 (os grupos criminosos) é a ameaça — o ator ou evento potencial que pode causar dano. Risco é a combinação da probabilidade de a ameaça explorar a vulnerabilidade e do impacto resultante; e o impacto é a magnitude da perda.

Questão 6: Alternativa C — Risco C — Probabilidade: alta; Impacto: crítico

Na priorização qualitativa, probability e impacto são combinados em uma pontuação geral. O Risco C une a maior probabilidade ('alta') com o maior impacto ('crítico'), gerando a maior pontuação agregada de risco e, portanto, a maior prioridade de remediação. O impacto crítico do Risco A é significativo, mas a probabilidade baixa reduz a pontuação combinada; o Risco B é um risco 'médio' intermediário; e o Risco D é frequente, porém causa apenas impacto menor.

Questão 7: Alternativa B — Avaliação qualitativa de riscos usando uma matriz de probabilidade e impacto

Uma avaliação qualitativa de riscos usa escalas ordinais — alto, médio, baixo — frequentemente plotadas em um mapa de calor ou matriz de riscos, e não exige avaliações patrimoniais em dólares, sendo rápida, fácil de comunicar aos executivos e adequada quando faltam dados confiáveis de valoração. As abordagens quantitativas (ALE, SLE, custo de reposição) exigem valores monetários precisos, que a organização não possui.

Questão 8: Alternativa D — Avaliação quantitativa de riscos com perda anualizada esperada (ALE)

Somente uma avaliação quantitativa de riscos gera resultados expressos em moeda. Usando valores de ativos, fatores de exposição e taxas de ocorrência, ela produz figuras de SLE e ALE — a perda anual esperada em dólares que o subscritor e o CFO precisam. Resultados qualitativos (mapas de calor, alto/médio/baixo), pontuações narrativas ad hoc e revisões de status do registro não podem fornecer estimativas de perda anual baseadas em valores monetários.

Questão 9: Alternativa B — Estabelecer uma cadência recorrente de avaliação de riscos que revalide e atualize todas as entradas do registro

As constatações descrevem um registro desatualizado: pontuações antigas nunca revalidadas e riscos novos ausentes. Um programa recorrente de avaliação de riscos reavalia periodicamente cada entrada frente aos controles atuais e adiciona os riscos introduzidos por novos projetos, mantendo o registro preciso e confiável. Depender apenas de revisões ad hoc, quando solicitadas, deixa longos intervalos sem avaliação; espalhar os dados em planilhas dos desenvolvedores destrói a fonte única da verdade; e forçar números por valoração quantitativa não corrige a falha de governança.

Questão 10: Alternativa C — Risco é a probabilidade de uma ameaça explorar uma vulnerabilidade e causar um impacto a um ativo

No modelo de riscos do Security+, $\text{Risco} = \text{Ameaça} \times \text{Vulnerabilidade} \times \text{Impacto}$ — ou, como definição, a probabilidade de que uma ameaça (um ator ou evento potencial, como ransomware) explore uma vulnerabilidade (uma fraqueza) e cause um impacto (perda ou consequência) a um ativo. Ameaça e vulnerabilidade são entradas do risco, não o risco em si; e o risco não é definido apenas pelo valor monetário de um ativo.